

01 / CURRENT STATE / RISK QUESTION

How far can one credential reach?

Scope of this design document

Rather than review many security risks, we focus on Maximum Extraction: how many records one misused credential can reach through the access paths we can verify.

We define Volume / Time / Seat / Destination / Exception to turn Current State into an implementable Target State and Verification conditions.

Assessment boundary

Design and verification cover the access paths you present, the information you provide, and the parts of the implementation available for review.

This does not guarantee the completeness of the entire system, including undisclosed or unknown paths, or the absence of every possible route for data leakage.

Example Mobility Co., Ltd.

Business: car sharing / vehicle rental

Example data: names, addresses, dates of birth, phone numbers, email, driving-license images, identity-verification documents, and payment-related information. No real data is used.

Current State

Path	Single operator	Per-request cap	Time total	Approval	Destination	Max reach
Admin CSV	Yes	10,000 records	None	None	None	All records
API	Yes	500 records	None	None	Fixed	All records
Full export	Yes	All records	Immediate	1 person*	None	All records

*In this fictional setup, the requester may also approve the full export. There is no independent Seat. Repeated CSV/API requests can also reach all records because there is no cumulative gate.

Risk Question

If one administrator credential is misused, how far can it reach?

Design Delta / Current → Target



500 is a per-request limit. The 24-hour total is 2,000. Full extraction uses a separate route.

Level 5 is a reference architecture, not a required configuration. Remove controls the workflow does not need, record why, and define the Target State.

Strong authentication lowers the likelihood of unauthorized entry;
Maximum Extraction after authentication needs a separate design.

This document is a deliverable sample for a completely fictional company. Actual design values are determined after reviewing operational requirements, existing controls, required immediacy, and allocation of responsibilities.

02 / TARGET STATE / DESIGN DELTA

Set release conditions for larger extractions.

Target State - illustrative values

Condition	Illustrative value / release condition
Normal access	500 records/request. A hard per-request cap on the normal path.
24-hour total	2,000 records. Sum all paths for the same principal and data scope over a rolling 24-hour window.
More than 2,000	Approval from someone other than the requester. Extraction stays within the approved scope and volume.
More than 10,000	At least two independent approvers + a waiting period. The requester does not count as an approver.
New destination	BLOCK / reapprove. A destination change invalidates the existing approval.
Recent privilege change	No large extraction immediately after the change. Release conditions and the delay follow company requirements.
Full dataset	Unavailable through the normal path. Acquired-data coverage and workflow scope also trigger a separate gate.
Emergency full extraction	Company-defined multi-party approval + a dedicated route + time constraints. No reuse for normal operations.

Bind approval to the requester, data scope, volume, destination, and expiry. Changes invalidate it; check it on each extraction. Waiting periods and exception expiry follow operational needs.

Gate / Time · Seat · Destination · Volume · Recovery

Time	Larger extractions wait. Define delays, expiry, and post-privilege-change timing.
Seat	Near-ALL access needs independent decisions. Separate requester/approver authority and credentials.
Destination	Approved destinations only; new or changed destinations trigger a separate gate.
Volume	Check per-request and cumulative totals across CSV, API, and export paths.
Recovery	Isolate emergencies: own scope, expiry, Seats, and evidence; define stop, revocation, and resumption.

Escalation Multisig Gate



Owner Seat alone cannot bypass the prior request, notification, WAIT, or required independent approvals. Bind approval to the request, release, scope, volume, destination, requester, release class, and expiry. Changes, expiry, or reuse for another release invalidate it.

One Level 5 example. Seat roles, counts, Owner policy, and waits follow company needs. An Owner policy can use 1 Owner or 2-of-3 Owner Seats; no quorum is the single correct model.

Normal access is limited to the data needed for the workflow. A 24-hour cap alone does not address full extraction through long-term repetition. Previously acquired data and proximity to the full dataset are also design and verification inputs.

03 / VERIFICATION / DELIVERY

Turn the design into verifiable conditions.

This is a verification plan using synthetic data. No implementation or execution testing has been performed for this sample.

Verification - planned / not executed

ID	Condition to verify	Expected decision / evidence to retain
V01	Does the per-request cap apply?	Compare normal requests for 500 and 501 records. Retain the decision log that blocks the excess request.
V02	Can split requests evade the cumulative cap?	Compare CSV/API totals of 2,000 and 2,001. Excess requires a separate Seat's approval; aggregate over a rolling 24-hour window.
V03	Does a new destination stop the release?	Change the destination after approval. Invalidate the old approval; retain the BLOCK / reapproval record.
V04	Can one compromised approver release the full dataset?	One approval alone does not release the full dataset. Verify independent Seats and requester exclusion.
V05	Can a recent privilege elevation enable large extraction?	Do not carry prior approvals forward. Stop large extraction and check the conditions for resuming.
V06	Can the emergency path become a normal route?	Stop exception use beyond its purpose, expiry, or scope. Retain revocation and action records.
V07	Can long-term repetition approach full extraction?	Check acquired-data coverage and workflow scope across days. Verify the separate gate for near-full access.

What the delivered design document contains

The same document connects leadership's decision on an acceptable Maximum Extraction bound with the changes and checks engineers need. Start with the relevant paths, limits, approvals, destinations, and exceptions; full-code disclosure is not required. Design can be commissioned separately, with internal implementation and a later external Verification.

Design	Current State by path, target values, Design Delta, gates, and exception flows.
Responsibility	Approval Seats, approved destinations, and who can stop, revoke, or resume access.
Verification	Test cases, results and evidence for work actually performed, and unverified scope. Record implementation/design gaps.

For a real engagement, establish data scope and the full dataset, waiting periods, independent approvers, destinations, exception expiry, and who may authorize exceptions to cumulative limits. Record agreed values, assumptions, and open decisions.

This document is a deliverable sample for a completely fictional company. Actual design values are determined after reviewing operational requirements, existing controls, required immediacy, and allocation of responsibilities.